HAUTE ÉCOLE D'INGÉNIERIE ET DE GESTION DU CANTON DE VAUD

CAA - Mini-projet

Ransomware post-quantique

Dylan Oliveira Ramos

06-12-2025

1. Description du ransomware

Nous avons un client (ordinateur de la victime) et un serveur (contrôlé par l'attaquant). Pour des raisons de simplicité, les deux entités sont exécutées dans le même programme.

Le client propose les options suivantes :
1. `Encrypt` : pour chiffrer tous les fichiers du dossier où se trouve le ransomware.
2. `Pay` : pour payer la rançon et obtenir la clé de déchiffrement.
3. `Unlock one file` : pour déchiffrer un fichier spécifique et payer une plus petite rançon.

Le serveur propose l'option suivante :
1. `Change password` : pour changer le mot de passe utilisé pour dériver la clé principale.

1.1. Niveau de sécurité choisi

Le ransomware utilise le niveau de sécurité **V**, qui offre une sécurité au moins aussi forte que AES-256.

1.2. Algorithmes utilisés

1.2.1. Chiffrement symétrique

Pour le chiffrement symétrique, nous utilisons l'algorithme **AES256-GCM** avec les paramètres suivants :
- Taille de la clé : 256 bits.
- Taille du nonce : 96 bits.
- Taille du tag : 128 bits.

Ces paramètres nous permettent de chiffrer des fichiers d'une taille maximale d'environ 68 GB.

1.2.2. Chiffrement asymétrique

Pour le chiffrement asymétrique, nous utilisons l'algorithme post-quantique **Kyber1024** avec les paramètres suivants :
- Taille de la clé publique : 1568 bytes.
- Taille de la clé privée : 3168 bytes.

Cet algorithme nous permet de garantir une sécurité au moins aussi forte que AES-256.

1.2.3. Dérivation de clé

Pour dériver la clé principale à partir du mot de passe, nous utilisons l'algorithme **Argon2id** avec les paramètres suivants :
- Taille du sel : 16 bytes.
- Taille de la clé dérivée : 32 bytes.
- Nombre d'itérations : 1.
- Degré de parallélisme : 4.
- Coût en mémoire : 65536 KB.

Une taille de clé dérivée de 32 bytes nous permet d'obtenir une clé principale compatible avec AES-256.

1.3. Processus de chiffrement

Le client et le serveur possèdent chacun une paire de clés publique/privée générée au démarrage du programme.

Lors du choix de l'option `Encrypt`, le ransomware effectue les étapes suivantes :

1. Le client obtient un d'un mot de passe aléatoire dans un dictionnaire, le chiffre avec la clé publique du serveur et lui envoie.
2. Le serveur dérive une clé à partir du mot de passe reçu, chiffre sa clé privée avec AES en utilisant cette clé dérivée et l'envoie au client.
3. Le client stocke la clé privée chiffrée du serveur dans un fichier à la racine du dossier.
4. Pour chaque fichier du dossier, le client génère une clé aléatoire et chiffre le fichier avec AES.
5. Chaque clé de fichier est chiffrée avec la clé publique du serveur et le triplet (clé chiffrée, nonce, tag) est stocké dans le fichier.

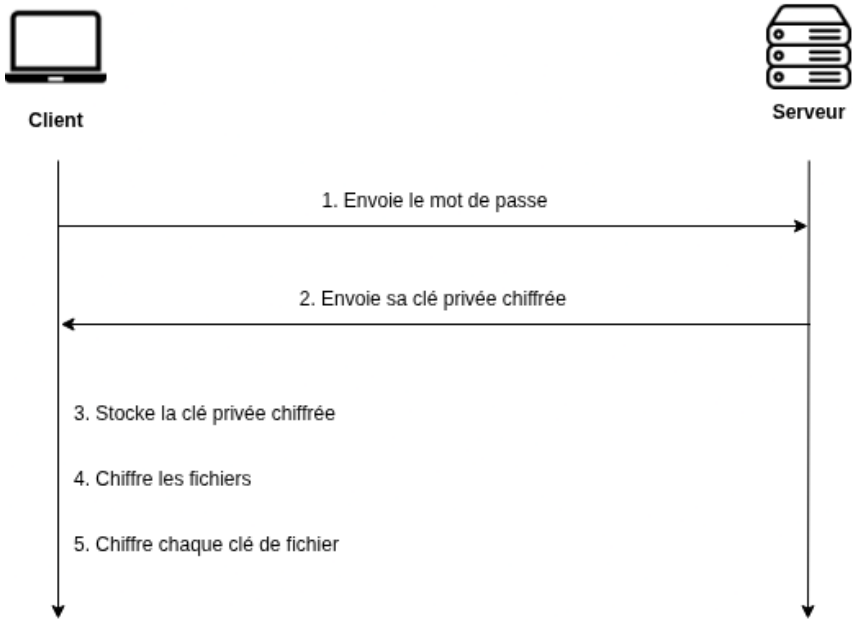

Fig. 1. – Étapes de chiffrement des fichiers.

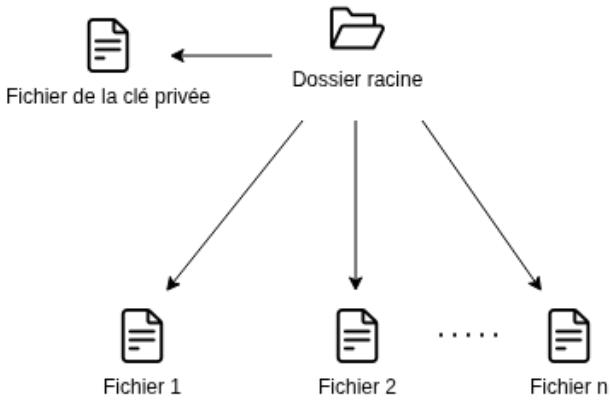

Fig. 2. – Structure du dossier après chiffrement.

Le fichier de la clé privée est structuré de la manière suivante :

```
clé privée chiffrée || nonce || tag
```

Les fichiers chiffrés de l'utilisateur sont structurés de la manière suivante :

```
clé de fichier chiffrée || nonce || tag || données chiffrées
```